

VENDOR RISK ASSESSMENT

The 5-Step Vendor Risk Assessment Process

<u>Step</u>	<u>What Happens</u>	<u>Key Questions to Ask</u>	<u>GreenLeaf Example</u>
1. Identity & Tier	Classify vendors by critically (Critical, Med, Low)	What does this vendor access? What happens if they are breached?	PaySecure = Critical Office supplier = Low
2. Request Evidence	Ask the vendor for security documentation	Do you have ISO27001? SOC 2 Type II ?Can you complete our security questionnaire?	Requested ISO27001, SOC 2 and Security Questionnaire
3. Review & Score	Evaluate the evidence against you criteria. Assign a risk score (High, Med, Low)	Does the evidence meet our minimum security requirement? Where are the gaps?	PaySecure = High risk (NO ISO, Outdated SOC2, no questionnaire history)
4. Decide Treatment	Choose a risk treatment option	Do we mitigate, transfer, accept, or avoid this vender?	Mitigate (Immediate contractual protections) Avoid (replace within 90 days)
5. Monitor	Continuously monitor the vendors security posture	Is their SOC 2 still current? Have there been any breaches?	Calendar reminder to reassess PaySecure quarterly or whether SOC 2 expires

Key Documents to Request from a Vendor

<u>Document</u>	<u>What It Proves</u>	<u>Why It Matters</u>
ISO 27001 Certification	Vendor has a formal audited Information Security Management System (ISMS)	Proves they have process n place to manage security continuously
SOC 2 Type II Report	Vendors actual operational controls were tested over a period of time (6-12 Months usually)	Proves they are doing what they claim, not just writing policies
Vendor Security Questionnaire	Answers specific questions not covered by the audits (e.g. Patching schedules, incident response)	Allows you to probe specific areas of concern (e.g. Do you store CVV numbers?)
Attestation of Compliance (AoC)	Proves the vendor is PCI DSS compliant (If they handle credit cards)	Required by your own compliance obligations

Vendor Risk Rating Criteria

<u>Rating</u>	<u>Criteria</u>	<u>Action Required</u>
Low Risk	Current ISO 27001 or SOC Type II. Questionnaire fully completed with no red flags	Accept, Monitor Anually
Medium	Outdated SOC Type II (>12M), Missing ISO 27001, but questionnaire shows adequate controls	Mitigate, add contractual protections, Monitor Quarterly
High	No ISO27001 , Outdated SOC 2 Type II (>18M) and questionnaire incomplete or refused	Mitigate (Immediate Protections) Avoid (Plan to Replace)
Critical	Vendor has suffered a known breach (<12M) AND lacks foundational controls	Avoid immediately Terminate the relationship

4 Treatment Options (Internal Risk)

<u>Option</u>	<u>Definition</u>	<u>When to Use</u>
Mitigate	Implement controls to reduce the risk (e.g. Contract, clauses, monitoring)	The vendor is critical but has some gaps. You want to keep the but impose strict conditions
Transfer	Shift the financial risk (e.g. Require the vendor to carry Cyber Insurance)	You want to keep the vendor but protect yourself financially from breach
Accept	Do nothing, but document the decision	The risk is Low/Medium and the cost of switching vendors is higher than the potential loss
Avoid	Terminate the relationship and find a new vendor	The risk is High/Critical and the vendor cannot meet your minimum requirements.

Quick Memory Trick

<u>Step</u>	<u>Analogy</u>
1. Identify & Tier	"Sorting your mail – what's important and what's junk?"
2. Request Evidence	Asking for a drivers licence before letting someone borrow your car
3. Review & Score	Checking if their licence is valid and they have insurance
4. Decide Treatment	Do you let them drive, ask them to get better insurance or say no
5. Monitor	Checking their driving record again next year